METASPLOITABLE 3 ENVIRONMENT

Updated Capstone Project 3 Penetration Test Report

Client: Midsize Organization — Legacy Development Environment

Assessment date: 11 September 2026

Prepared by: Group 4 · Penetration Testing Specialists

Report status: Complete

This report documents an authorized laboratory assessment of a Metasploitable 3 hybrid environment. It incorporates the supplied detailed report while correcting scope, evidence, vulnerability terminology, timeline, and asset-mapping inconsistencies.

1. Confidentiality Statement

This document contains proprietary and confidential security assessment information. Unauthorized duplication, disclosure, or distribution is prohibited. Access is restricted to authorized personnel and approved academic assessors. Findings are intended for the internal security team and authorized stakeholders only.

2. Disclaimer

This assessment is a snapshot of the authorized laboratory environment as observed on 11 September 2026. The results may change after system, network, application, credential, or monitoring changes. The absence of a finding does not prove that a vulnerability is absent. Testing was controlled, limited to the defined scope, and is not an exhaustive assessment of a production organization.

3. Contact Information

Name	Title	Contact Information
Group 4	Penetration Testing Specialists	[Replace with approved team email]
Assessment Lead	Junior Penetration Tester	[Replace with approved assessor contact]
Client Point of Contact	Security Team Lead	[Replace with approved client contact]

The addresses supplied in the draft were treated as laboratory placeholders and should be replaced or explicitly labelled before distribution.

4. Scope

In-scope assets

Asset ID	Description	Platform	IP address	Confirmed role
ASSET-01	Target Linux machine	Ubuntu 14.04.5 LTS	192.168.56.102	Linux services and web/application surface; verify each service against final raw scan.
ASSET-02	Target Windows machine	Windows Server 2008 R2 Enterprise x64	192.168.56.101	Windows services including SMB; verify other services against final raw scan.
ASSET-03	Custom web infrastructure	Python/Flask application	192.168.56.102	Application surface; exact port must be confirmed from final scan.
ASSET-04	Diagnostic/admin endpoint	Administrative API utilities route	192.168.56.102	Endpoint requires evidence confirmation before being treated as exploitable.
ASSET-05	Relational database engine	Legacy database service	192.168.56.101 or .102	Exact host mapping must be confirmed from raw scan evidence.

Network range: 192.168.56.0/24. **Testing platform:** Kali Linux at 192.168.56.1. **Services assessed:** SMB, RDP, IIS/GlassFish where present, SSH, Apache, ProFTPD, MySQL, and the custom web application/API surface. The final submitted evidence must be used to confirm exact host-to-service mappings.

Scope exclusions

• Production systems outside the designated development subnet.

• Client employee workstations.

• Third-party cloud infrastructure.

• Social engineering and phishing.

• Denial-of-service testing, destructive actions, uncontrolled data extraction, and unapproved persistence.

Client allowances

• Testing was conducted from Kali Linux within the isolated authorized subnet.

• Wazuh telemetry was available for defensive-monitoring validation.

• Exploitation was authorized only against the listed laboratory assets and under controlled conditions.

• No testing was authorized against systems outside the defined scope.

5. Executive Summary

Group 4 assessed a legacy development environment consisting of Windows Server 2008 R2 and Ubuntu 14.04.5 LTS hosts running outdated services, weak credentials, and application components. The objective was to identify exploitable attack paths, validate selected defensive visibility, test custom Python tooling, and produce a prioritized remediation plan.

The assessment records 11 findings: 2 Critical, 3 High, 4 Medium, and 2 Low. The highest-risk validated paths involved SMB exposure associated with MS17-010/EternalBlue and ProFTPD mod_copy arbitrary file operations chained to code execution in the laboratory. Weak credentials and reflected XSS increased the likelihood of unauthorized access, credential misuse, session compromise, and lateral movement.

Severity	Count	Meaning
Critical	2	Potential for direct privileged host compromise; immediate isolation and remediation required.
High	3	Likely unauthorized access or significant lateral-movement capability; remediate urgently.
Medium	4	Material exposure requiring planned remediation and compensating controls.
Low	2	Lower-impact hardening weaknesses that should still be addressed.

Overall recommendation: Isolate the development subnet, disable SMBv1, patch or retire vulnerable services, remove default credentials, restrict administrative interfaces, remediate reflected XSS, and perform a verification retest after remediation.

Claims such as full-chain execution in under 30 minutes, packet-capture confirmation, and Wazuh detection should be retained only if the corresponding raw evidence is attached or archived and referenced by timestamp.

6. Methodology

The assessment followed a controlled sequence informed by penetration-testing and web-application testing practices. The report uses four operational phases.

Phase	Activities	Tools/evidence
1. Reconnaissance	Host discovery, OS fingerprinting, service banners, network mapping, and independent port validation without exploitation.	Nmap; custom Python TCP scanner.
2. Enumeration and scanning	SMB, FTP, SSH, web, API, and database enumeration; vulnerability scanning; targeted reflected-XSS checks.	Nessus/OpenVAS/Greenbone; Nmap; custom web scanner; manual enumeration.
3. Exploitation and post-exploitation	Controlled validation of confirmed issues, privilege confirmation, credential checks, lateral-movement review, and data-access checks within scope.	Metasploit; manual application validation; controlled shell checks; Wazuh.
4. Evidence and reporting	Evidence consolidation, severity and likelihood/impact ranking, remediation mapping, peer-review updates, and final packaging.	Archived terminal output, scan exports, screenshots, and findings register.

Tool workflow

Reconnaissance used Nmap and the custom port scanner. Enumeration used service-specific checks, Nessus/OpenVAS or Greenbone, and the custom web scanner. Exploitation used Metasploit and controlled manual validation. Post-exploitation checked privilege, credential reuse, lateral movement, and defensive alerts. Raw outputs should be retained so every confirmed finding can be traced to evidence.

7. Findings Summary

Severity reflects the project risk model. CVSS vectors should be added only after the final evidence and affected-service mapping have been verified.

ID	Finding	Severity	Impact	Affected asset	Recommendation
F-01	SMBv1 / MS17-010 (EternalBlue) remote code execution	Critical	Unauthenticated remote code execution and potential SYSTEM-level host takeover.	ASSET-02; 192.168.56.101; TCP 445	Apply the applicable Microsoft security update; disable SMBv1; restrict TCP 445; retest.
F-02	ProFTPD mod_copy arbitrary file copy/write — CVE-2015-3306	Critical	Unauthenticated file manipulation may be chained to application execution and root-level compromise.	ASSET-01; 192.168.56.102; TCP 21, if confirmed	Upgrade or retire the vulnerable service; disable mod_copy/anonymous access; migrate to SFTP; retest.
F-03	Default or weak credentials	High	Unauthorized SSH/MySQL access, credential reuse, and lateral movement.	ASSET-01/02; exact service mapping to verify	Rotate all credentials; remove defaults; disable root SSH; enforce least privilege and MFA where feasible.
F-04	Reflected cross-site scripting	Medium / P1	May enable session compromise or unauthorized actions against authenticated users, depending on cookie and browser protections.	ASSET-03; affected query parameter and port to verify	Apply contextual output encoding, validation, safe templating, CSP, and secure-cookie controls.
F-05	Exposed diagnostic or command-execution route	High if confirmed	Could permit unauthorized application or host actions.	ASSET-04; 192.168.56.102	Remove debug routes; require authentication/authorization; restrict management access; validate commands safely.
F-06	SUID root binary misconfiguration	Medium	Local privilege escalation after an initial foothold.	ASSET-01 Linux host	Remove unnecessary SUID permissions; review ownership and permissions; monitor privilege changes.
F-07	SQL injection or unsafe backend input handling	Unconfirmed / Medium if verified	Potential database disclosure or modification.	Web/API and database tier	Add only if supported by exploit evidence; use parameterized queries, validation, and least-privilege database accounts.
F-08	Cleartext database transport	Medium	Credentials and database traffic may be exposed to network interception.	ASSET-05; TCP 3306, exact host to verify	Require TLS; restrict database binding and firewall access; segment the database tier.
F-09	Unauthenticated SMB listing	Medium	Share and file-name disclosure assists reconnaissance and further compromise.	ASSET-02; TCP 445	Disable guest/anonymous access; require authentication; apply least-privilege share permissions.
F-10	Outdated SSL/TLS cipher configuration	Low/Medium if verified	Weak cryptographic settings reduce transport confidentiality.	TLS-enabled service, exact endpoint to verify	Disable obsolete protocols/ciphers and enforce current secure configurations.
F-11	Banner disclosure, directory browsing, and ICMP timestamp responses	Low	Information disclosure assists reconnaissance.	Affected web/network services to verify	Suppress banners, disable directory indexing, and restrict ICMP timestamp requests where appropriate.

The three items marked “unconfirmed” or “if verified” should not be presented as fully validated findings unless the supporting scan, capture, or exploitation evidence is included. If the assignment requires exactly 11 confirmed findings, replace them with verified evidence-backed findings or change the report language to “observed/tested.”

8. Exploitation Details

8.1 SMB remote code execution

Finding: The Windows target at 192.168.56.101 was reported as exposing SMBv1 on TCP 445 and vulnerable to the MS17-010 attack path. The supplied evidence states that controlled Metasploit validation resulted in a Meterpreter session and SYSTEM-level identity.

Evidence status: Include the actual redacted Metasploit output and session confirmation in the appendix. The draft output contains both “Exploit completed, but no session was created” and a subsequent session-opened message; retain the complete chronological output and explain the sequence rather than deleting the contradictory line.

Impact: Successful exploitation can provide complete host control and a platform for lateral movement. Testing must remain limited to the authorized laboratory target.

8.2 ProFTPD mod_copy

Finding: The Linux target at 192.168.56.102 was reported as running ProFTPD 1.3.5. The more precise vulnerability description is an arbitrary file copy/write condition associated with mod_copy, commonly mapped to CVE-2015-3306, rather than simply calling it a “backdoor.”

Evidence status: Attach the service fingerprint, Metasploit output, resulting shell identity, and the controlled file-operation evidence. Confirm that the service and module actually correspond to the final target configuration.

8.3 Reflected XSS

Finding: The custom scanner reported an unescaped test payload reflected in a query response. Manual browser confirmation was reported. The impact should be stated conditionally unless authenticated context, cookie flags, and user privileges were tested.

Evidence status: Attach the scanner output, affected URL and parameter, response excerpt, and a non-destructive browser confirmation. Do not include real user session tokens or credentials.

9. Security Strengths

• Wazuh provided defensive telemetry for selected assessment activity, although alert coverage requires tuning.

• The custom port scanner provided independent validation of automated scan results.

• The custom web scanner tested encoding variants and generated evidence output.

• The development environment was isolated from production, limiting blast radius if that boundary is accurate and enforced.

• Findings were connected to remediation actions and a retest recommendation.

• The assessment used layered methods across network, host, application, and monitoring controls.

10. Security Weaknesses

• End-of-life Windows and Linux platforms and outdated services increase exposure to known attacks.

• SMB, FTP, SSH, database, and web services create multiple entry points.

• Default credentials permit trivial unauthorized access and reuse.

• A flat development subnet permits rapid inter-host movement after compromise.

• Application input handling and diagnostic routes require stronger controls.

• Cleartext or weakly protected administrative and database traffic increases interception risk.

• Wazuh may detect noisy scanning more reliably than quiet targeted exploitation.

11. Remediation Recommendations

Priority	Window	Actions
P1 — Immediate	Within 24 hours	Isolate the development subnet; disable SMBv1; apply relevant Windows patches; stop or restrict vulnerable ProFTPD; disable exposed debug/command routes; begin credential rotation.
P1 — Urgent	Within 7 days	Remove default accounts/passwords; disable root SSH; restrict SMB, FTP, SSH, MySQL, and management interfaces; review Wazuh detection rules.
P2 — Application	Within 14 days	Fix reflected XSS and any verified injection using contextual encoding, parameterized queries, secure cookies, CSP, validation, and regression tests.
P2 — Host hardening	Within 14 days	Remove unnecessary SUID permissions; disable guest SMB access; correct share permissions; remove directory listings and unnecessary banners.
P3 — Architecture	Within 30 days	Segment development, management, application, and database tiers; enforce TLS for database traffic; centralize secrets; complete a verification retest.

12. Conclusion & Reflection

The assessment demonstrates that a legacy hybrid development environment can expose several independent routes to privileged compromise. The most important lesson is that vulnerable services, weak credentials, flat networking, and application weaknesses compound one another. Custom scanning improved understanding of the attack surface, while Wazuh testing showed that detection quality must be assessed alongside prevention and remediation.

What went well included the structured workflow, independent port validation, targeted XSS detection, and evidence-oriented reporting. Challenges included reconciling automated output, validating service-to-IP mappings, distinguishing confirmed findings from hypotheses, and assessing quiet exploitation. A future assessment should define an evidence schema before testing, record exact tool versions and timestamps, apply consistent CVSS v3.1 scoring, expand authenticated application testing, and automate evidence collection while redacting sensitive data.

13. Change Log

Date	Change	Reason
11 September 2026	Updated asset table and separated confirmed mappings from services requiring verification.	Resolve Windows/Linux and service-mapping inconsistencies.
11 September 2026	Renamed ProFTPD issue to mod_copy arbitrary file copy/write and added CVE-2015-3306 wording.	Improve technical accuracy.
11 September 2026	Clarified that XSS severity, session impact, and P1 priority require contextual justification.	Avoid overstating application impact.
11 September 2026	Restricted exploitation allowance to authorized laboratory assets and non-destructive testing.	Improve scope and safety language.
11 September 2026	Added evidence-status notes and corrected future-dated change-log entries.	Improve traceability and timeline consistency.

Replace these entries with the actual peer/mentor feedback and dates if the critique occurred on different dates. Do not retain dates after the report submission date.

Appendix A — Custom Port Scanner Output

Use only output captured from the final authorized scan. The example below is retained as a template and must be checked against the final host mapping:

python3 port_scanner.py -t 192.168.56.101 -p 21,22,80,445,3306 [+] Initializing raw socket connect scan [+] Scan complete: 5 ports checked | 5 open | Elapsed: 1.42s

The service labels in the original example must not be copied into the final report unless the final raw scan confirms them on 192.168.56.101.

Appendix B — Custom Web Scanner Output

python3 web_xss_scanner.py -u http://192.168.56.102/search.php -p query [+] Injecting test canary: alert('CAPSTONE_XSS') [!] Unescaped payload reflected in tag context [✓] Evidence logged to report_findings.json

Replace the endpoint and output with the actual final application route and retained evidence. The draft refers both to port 80 and port 5000; one verified mapping must be selected.

Appendix C — Evidence Checklist

- Authorization and scope confirmation.
- Verified asset-to-IP-to-service matrix.
- Nmap discovery and service/version output.
- Custom port-scanner source, command, raw output, and comparison notes.
- Nessus/OpenVAS/Greenbone scan export and false-positive review.
- Redacted Metasploit validation output for authorized findings.
- Custom web-scanner source, payload list, response evidence, and JSON output.

• Wazuh alerts correlated to scan and exploitation timestamps.

• Screenshots with tokens, credentials, and unnecessary personal data removed.

• Retest results confirming remediation.

Appendix D — Risk Matrix

Likelihood / Impact	Low impact	Medium impact	High impact
High likelihood	Medium	High	Critical
Medium likelihood	Low/Medium	Medium	High
Low likelihood	Low	Low/Medium	Medium

Appendix E — Tools Used

Tool	Purpose
Nmap	Host discovery, port scanning, and service fingerprinting.
Metasploit Framework	Controlled exploitation and post-exploitation validation.
Nessus/OpenVAS/Greenbone	Automated vulnerability scanning and cross-validation.
Custom Python port scanner	Independent TCP service validation.
Custom Python web scanner	Targeted reflected-XSS detection.
Wazuh	Defensive detection and telemetry validation.
Kali Linux	Authorized assessment platform.

Prepared by Group 4 — Penetration Testing Specialists. Assessment date: 11 September 2026. Report version: 2.0.